

User Authentication

4.1 User Authentication Principles

4.2 Password-Based Authentication

4.3 Token-Based Authentication

4.4 Biometric Authentication

4.5 Remote User Authentication

4.6 Two Factor Authentication

User Authentication

- User authentication refers to the process of **verifying the identity of a user who is attempting to access** a particular system or application.
- It involves confirming that the user is **who they claim to be**, and typically involves the use of **usernames and passwords**, or other forms of **credentials such as biometrics** (fingerprint or facial recognition), **security tokens, or smart cards**.
- The purpose of user authentication is to **prevent unauthorized access to a system or application**, and to **protect sensitive information** that may be **stored or transmitted** through the system. By verifying the identity of a user, the system can ensure that **only authorized individuals are able to access the system** and the data within it.

Some of the most common methods include:

- **Password-based authentication** - the user enters a username and password to access the system.
- **Biometric authentication** - the user provides a physical characteristic such as a fingerprint or facial recognition for identification.
- **Two-factor authentication** - the user provides two forms of authentication such as a password and a security token or a fingerprint and a smart card.
- **Multi-factor authentication** - the user provides multiple forms of authentication such as a password, a security token, and a fingerprint.

User Authentication Principles

1. **Identification:** The user authentication system should enable the user to identify themselves to the system with a **unique identifier, such as a username, email address, or employee ID**.
2. **Verification:** The system should verify that the user is who they claim to be by requiring them to provide a password or other form of authentication, such as a **fingerprint, smart card, or security token**.
3. **Authentication Factors:** The system should use multiple authentication factors, such as something the user knows (e.g. a **password**), something the user has (e.g. a **smart card**), and something the user is (e.g. a **biometric feature**).
4. **Access Control:** The system should **grant access to resources and data** only to authorized users who have successfully authenticated themselves.
5. **User Education:** The system should educate users about the importance of security and provide guidance on **how to create strong passwords, avoid phishing scams, and protect their devices and credentials**.
6. **User Privacy:** The system should **protect user privacy by collecting only the minimum amount of data** necessary for authentication purposes and by storing that data securely.
7. **Continuous Monitoring:** The system should continuously **monitor user activity to detect and respond to potential security threats**, such as suspicious login attempts or unauthorized access attempts.
8. **Compliance:** The system should comply with relevant **security standards, regulations, and best practices**, such as the ISO 27001, NIST Cybersecurity Framework, and PCI DSS.

User Authentication Principles

9. **Least Privilege:** Users should be granted the **minimum level of access** required to perform their tasks, based on the principle of least privilege. This **reduces the risk of unauthorized access and limits the damage** that can be caused in case of a security breach.
10. **Strong Authentication:** The authentication process should use strong authentication mechanisms, such as **multi-factor authentication**, to reduce the risk of unauthorized access due to **weak passwords or compromised credentials**.
11. **Secure Storage of Credentials:** User credentials should be stored securely, using encryption and other security measures, to prevent unauthorized access to the credentials in case of a security breach.
12. **Secure Communication:** Authentication communication should be **secure, using encryption** and other security measures, to **prevent unauthorized interception or modification** of authentication data.
13. **Auditability:** The authentication process should be auditable, allowing administrators to **review the authentication logs and identify any potential security issues** or anomalies.

Password-based authentication

- Password-based authentication is a **process of verifying the identity of a user by requiring them to provide a username and password**.
- It is a widely used authentication method in computer systems and applications, as it is simple and familiar to users. However, password-based authentication can be **vulnerable to various security risks, such as password guessing, brute-force attacks, and phishing**.

To mitigate these risks, it is essential to follow best practices for password-based authentication, including:

- **Strong Password Policy:** Require users to create strong passwords that are difficult to guess, such as a **combination of letters, numbers, and symbols**. Enforce regular password changes, and prevent users from using the **same password across multiple accounts**.
- **Password Encryption:** Passwords should be **encrypted and stored securely**, using a **strong hashing algorithm**, to prevent unauthorized access in case of a data breach. The **stored password should not be recoverable**, even by the system administrators.
- **Two-Factor Authentication (2FA):** Implementing two-factor authentication can provide an additional layer of security, requiring the user to provide **a second form of authentication, such as a security token, in addition to their password**.
- **Account Lockout:** After a certain number of **incorrect login attempts**, the **account should be locked out to prevent brute-force attacks**. The lockout duration should be sufficient to discourage attackers, **but not too long to inconvenience users**.
- **Regular Security Audits:** Regular security audits can help identify and mitigate potential security vulnerabilities in the password-based authentication process, such as **weak password policies, outdated encryption algorithms, or unauthorized access**.

Common password selection strategies

Some common password selection strategies:

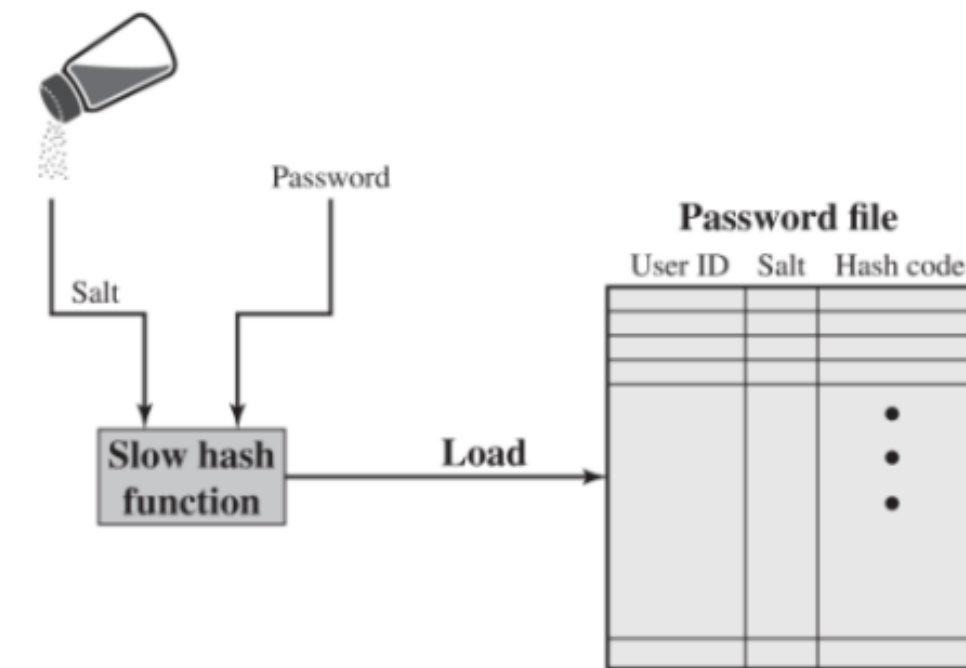
- **Use a passphrase:** A passphrase is a long and complex sentence that is **easy to remember but difficult to guess**. A passphrase should consist of **at least 4-5 words, and should not be a commonly known phrase or quote**.
- **Use a combination of characters:** Use a **mix of upper and lower case letters, numbers, and special characters, such as #, \$, or %, to create a strong and unique password**.
- **Avoid common words:** Avoid using common words or phrases that can be **easily guessed or found in a dictionary**. Instead, use a **mix of random words or use misspellings, abbreviations, or acronyms**.
- **Use a password manager:** A password manager is a **software that helps users generate and store complex and unique passwords securely**. Users only need to remember one master password to access their stored passwords.
- **Don't reuse passwords:** Never reuse passwords across multiple accounts, as this can increase the risk of compromise. Instead, use a **unique password for each account**.
- **Change passwords regularly:** Regularly changing passwords can help **prevent password guessing and cracking**. Users should change their **passwords every 60 to 90 days**.
- **Use multi-factor authentication:** Multi-factor authentication adds an **additional layer of security** to the authentication process by requiring a user to provide **multiple forms of identification, such as a password and a fingerprint scan**.

Some common types of cracking of user-chosen passwords

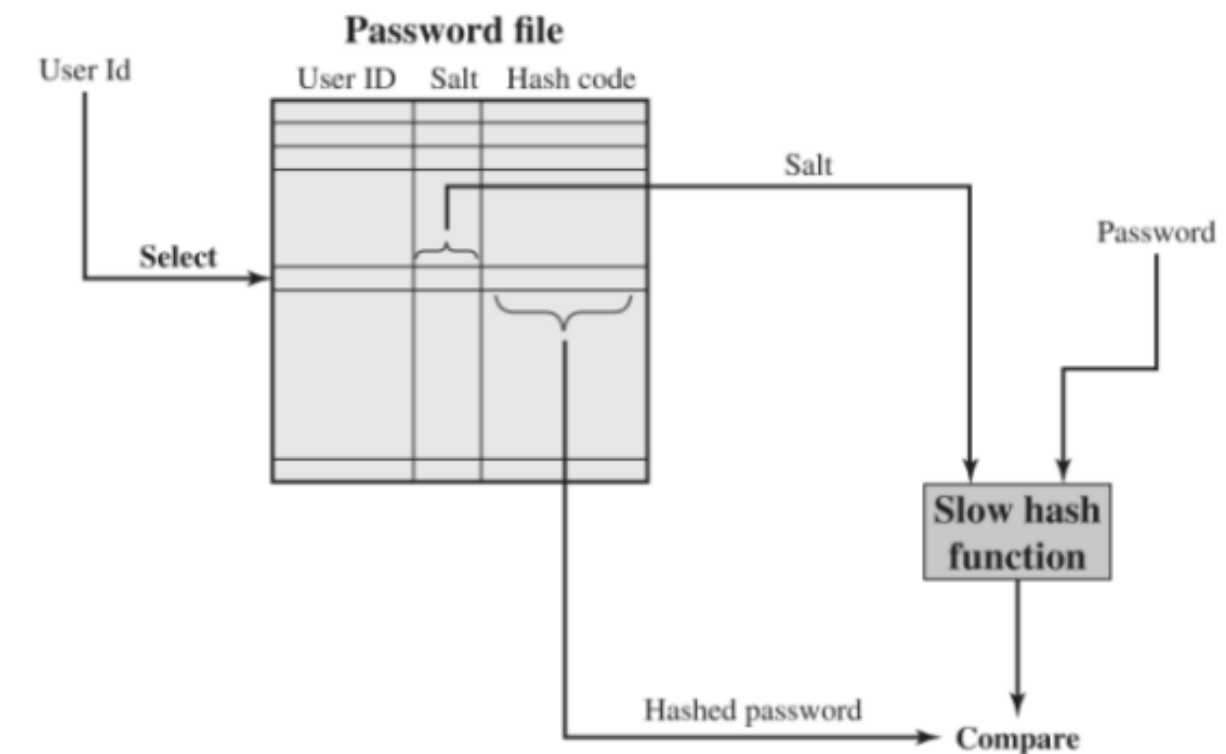
- **Brute-force attack:** This involves trying every possible combination of characters until the correct password is discovered. Brute-force attacks can be time-consuming and resource-intensive, but they can be effective against weak passwords.
- **Dictionary attack:** This involves using a list of commonly used passwords, dictionary words, or variations of them to attempt to guess the password. Dictionary attacks are faster than brute-force attacks and can be effective against weak and common passwords.
- **Rainbow table attack:** This involves using precomputed tables of **password hashes to quickly crack passwords**. Rainbow table attacks are effective **against simple and weak passwords** but can be prevented by using salted hashes.
- **Social engineering:** This involves using deception or manipulation to **trick users into revealing their passwords**. Social engineering attacks can be highly effective, especially when combined **with phishing emails or other forms of online fraud**.
- **Keylogging:** This involves using software or hardware to **record keystrokes entered by a user**, including passwords. Keylogging attacks can be difficult to detect and can be effective against **any type of password**.
- **Shoulder surfing:** This involves observing a user as they enter their password, either in person or through video surveillance. Shoulder surfing attacks can be **difficult to prevent** and are most effective against weak passwords.

The Use of Hashed Passwords

- A salt is a random string of characters that is generated and added to a user's password before it is hashed. The purpose of a salt is to **prevent attackers** from using precomputed rainbow tables or other similar attacks that exploit the fact that many people use common passwords. By **adding a unique salt to each password**, even if two users have the same password, their hashed values will be different.
- When a user logs in, their password is combined with the salt and hashed using a one-way hash function. The resulting hash value is then compared to the stored hash value for that user's account. If the **two hash values match**, the user is granted access.



(a) Loading a new password



(b) Verifying a password

Token-based authentication

- Token-based authentication is a type of authentication mechanism used in web applications, where a user is authenticated by **sending a token** with each request to the server instead of sending the user's credentials (such as username and password) with every request.
- The token is a **unique string of characters** that is generated by the server and sent to the client (usually in the form of a cookie or HTTP header) upon successful login.
- The client then includes the token with each subsequent request, allowing the server to verify the user's identity and grant access to protected resources.
- There are different types of tokens used **in token-based authentication**, including **JSON Web Tokens (JWTs), OAuth tokens, and session tokens**.
- JWTs are a popular choice as they **are self-contained**, meaning that they contain all the necessary information to authenticate a user and authorize access to resources.

Token-based authentication

- Token-based authentication is a method of authentication that uses a physical device, such as a **memory card, smart card, or electronic identity card**, to verify the identity of a user.
- **Memory cards** are small, portable storage devices that can be used to store authentication credentials, such as passwords or digital certificates. When a user wants to authenticate, they insert the memory card into a **reader device** and enter their password. The reader device then reads the authentication credentials from the memory card and verifies them.
- **Smart cards** are similar to memory cards, but they have an embedded **microprocessor** that can perform more advanced security functions. Smart cards can be used to **store digital certificates, biometric data, and other types of authentication credentials**. When a user wants to authenticate, they insert the smart card into a **reader device** and enter their password. The reader device then communicates with the smart card's microprocessor to verify the user's identity.
- **Electronic identity cards (eID cards)** are government-issued **identity cards** that contain an **embedded microprocessor** and can be used for authentication purposes. eID cards are typically used for **government services, such as tax filing, voting, or accessing government websites**. When a user wants to authenticate using an eID card, they insert the card into a reader device and enter their PIN. The reader device then communicates with the **card's microprocessor to verify the user's identity**.

Token-based authentication

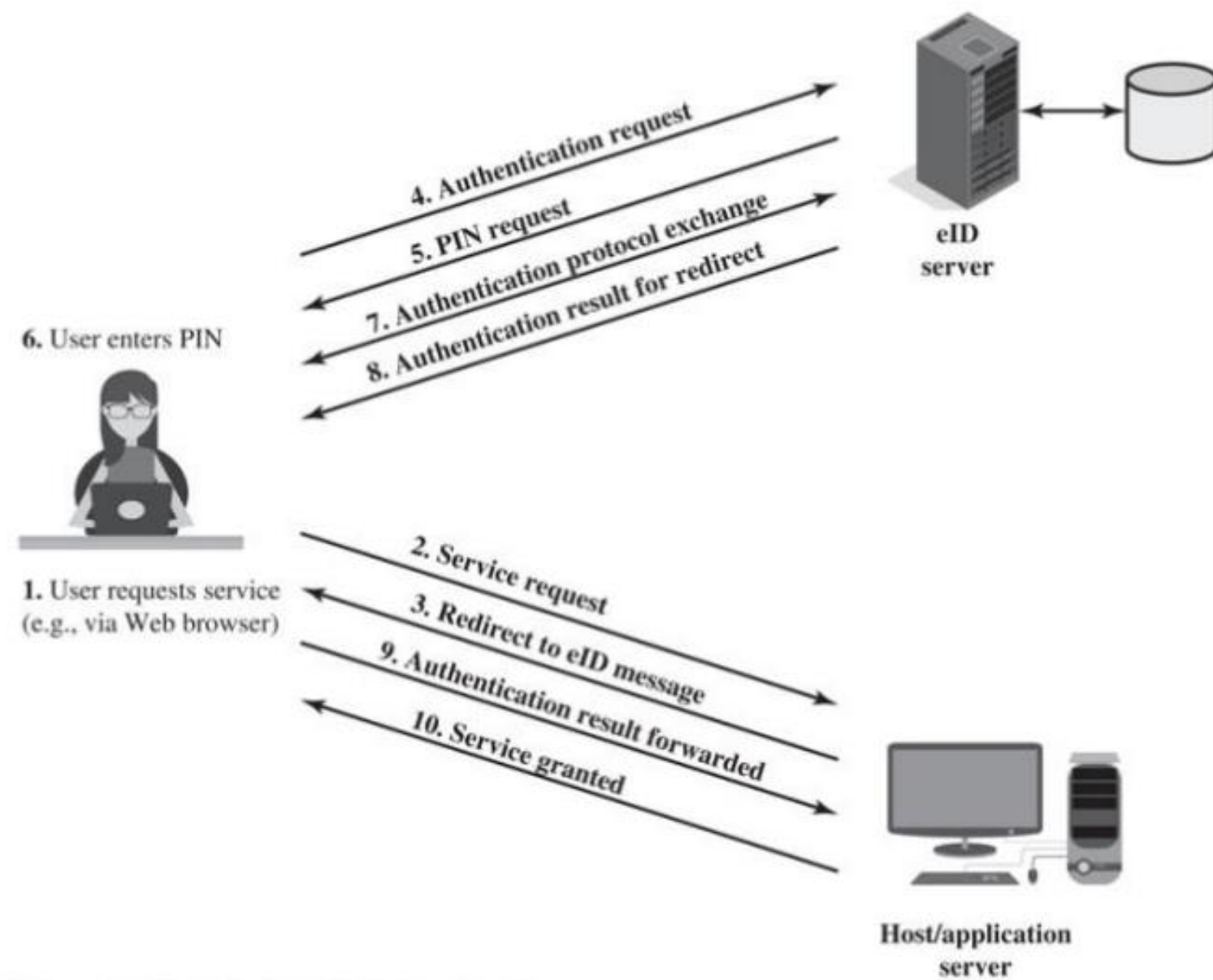


Figure 3.7 User Authentication with eID

Token-based authentication

Advantages of token-based authentication:

- **Higher level of security** than traditional password-based authentication
- Can be used for **multi-factor authentication**
- Can be used in **situations with limited** .
- Can **store large amounts of authentication** data

Disadvantages of token-based authentication:

- Requires users to carry a **physical device** with them
- **More expensive and complicated** to implement than traditional password-based authentication
- **Physical devices can be lost** or stolen

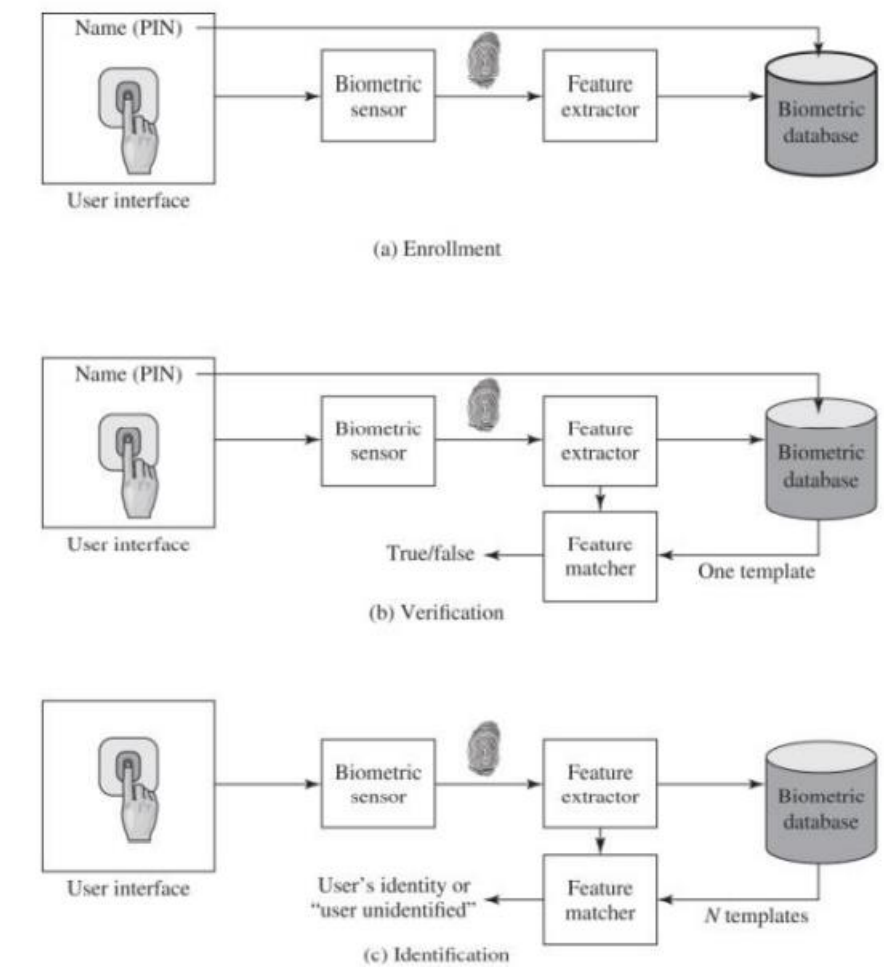
Token-based authentication: Biometric authentication

- Biometric authentication is a method of verifying the identity of a user based on their unique physical or behavioral characteristics. This method of authentication is often used as a more secure alternative to traditional password-based authentication methods.

Types of Biometric Authentication:

- Fingerprint recognition
- Facial recognition
- Retinal or iris recognition
- Voice recognition
- Signature recognition
- Hand geometry
- Behavioral biometrics, such as keystroke dynamics or gait(work) recognition

Token-based authentication: Biometric authentication



Process of Biometric Authentication:

- **Enrollment:** The user's biometric data is captured and stored in a database.
- **Authentication request:** The user requests access to a system or application.
- **Biometric verification:** The user's biometric data is captured again and compared to the stored biometric data to verify their identity.
- **Access granted or denied:** The user is granted access to the system or application if their biometric data matches the stored data, or denied access if it does not.

Token-based authentication: Remote user authentication

- Remote user authentication is the process of **verifying the identity** of a user who is accessing a system or application **from a remote location**, typically over a network such **as the internet**.
- There are several methods that can be used for remote user authentication, including:
 - Password-based authentication:
 - Two-factor authentication:
 - Biometric authentication:
 - Token-based authentication:

When implementing remote user authentication, it is important to consider the security **risks and select appropriate authentication** methods based on the level of security required and the needs of the users.

It is also important to **regularly review and update authentication methods** to ensure they remain effective against evolving threats.

Token-based authentication: Protocols

- **Password Protocol:** This is a basic protocol that requires users to enter a **username and password to access a system or application remotely**. Passwords should be **strong, unique, and regularly changed to improve security**. However, password-based authentication can be **vulnerable to attacks such as phishing, brute-force attacks, and password theft**.
- **Token Protocol:** This protocol involves providing the user with a **physical device, such as a smart card or USB token, that contains authentication credentials**. The user inserts the device into their computer or provides a **one-time code generated by the device to access the system or application**. Token-based authentication can be more secure than password-based authentication, as the user must have physical possession of the token to access the system or application.
- **Static Biometric Protocol:** This protocol involves verifying the **user's identity based on a physical or behavioral characteristic that is unique to the individual, such as a fingerprint or facial recognition**. Static biometric authentication can be more secure than password-based authentication, as the user cannot easily share or replicate their biometric data. However, static biometric data can still be stolen or compromised, and there are concerns about the privacy and security of biometric data.
- **Dynamic Biometric Protocol:** This protocol involves verifying the user's identity based on a **behavioral characteristic that is unique to the individual, such as typing speed or mouse movements**. Dynamic biometric authentication can be more secure than password-based authentication, as it is more **difficult for attackers to replicate or steal the user's behavioral data**. However, this method can be more difficult to implement and may not be suitable for all users.
- **Two-Factor Authentication Protocol:** This protocol involves requiring the user to provide **two different types of authentication factors to access the system or application**. For example, the user may **provide a password and a one-time code sent to their mobile device or generated by an authentication app**. Two-factor authentication can provide an additional layer of security, making it more difficult for attackers to gain unauthorized access.

Authentication factors

- Authentication factors are the different types of information or data that are used to verify the identity of a user. The five common authentication factors are:
- **Knowledge factor:** This involves verifying something that the user knows, such as a password or a personal identification number (PIN).
- **Possession factor:** This involves verifying something that the user has, such as a physical token, smart card, or mobile device.
- **Inherence factor:** This involves verifying something that is a part of the user, such as a biometric trait like a fingerprint, iris pattern, or facial recognition.
- **Location factor:** This involves verifying the user's location, typically using GPS or IP address information.
- **Time factor:** This involves verifying the time of the user's authentication attempt, typically using time-based one-time passwords (TOTP) or similar mechanisms.